Website Vulnerability Scanner: Experimental Results

Team WVS: Deepthi (241IT021), Jasmine (241IT051) and Sacheth Koushal (241IT058). Software Engineering (IT303), October 12, 2026.

1. Aim

Measure how well WVS finds real weaknesses on a website it is allowed to scan, how long a scan takes, and whether the code behaves as specified.

2. Setup

- **Target:** `vuln-lab`, a deliberately weak test website (source in `tools/vuln-lab`), deployed at `http://vuln-lab.sacheth.tech`. Each weakness is planted for one or more detectors, as listed in `tools/vuln-lab/README.md`.
- **Ownership:** verified with the well-known file method before scanning, as WVS requires.
- **Scan:** STANDARD profile (10 requests per second, concurrency 5, depth 5, at most 200 pages and 2,000 requests). Only `/logout` was excluded from scope.
- **Scan ID:** `cmv4r3v5f0009x8p455ba5tyj`, run on October 12, 2026.
- **Stack:** WVS running locally (React web app, Express API, BullMQ scan worker, PostgreSQL 16, Redis 7).

3. Results at a glance

33 / 34
planted detector checks found (97%)

64
findings reported

52 s
scan time (32 pages, 126 requests)

1,233
automated tests passed, 0 failed

Severity	Findings
Critical	17
High	8
Medium	20
Low	13
Info	6

Total	64

No detector raised an execution error during the scan.

4. Planted weaknesses compared with findings

Detector(s)	Planted weakness	Found by the scan	Result
P–01, P–03..P–06, A–06	No security headers on any HTML page	P-01, P-03, P-04, P-05, P-06, A-06 all reported	Detected
P–07, P–08, P–09	PHPSESSID cookie with no flags	2 cookies each for Secure, HttpOnly, SameSite	Detected
P–10	lab_theme cookie scoped to Domain=sacheth.tech	1	Detected
P–17	Server: Apache/2.4.49, X-Powered-By: PHP/5.6.40	2	Detected
P–18	Same headers, jQuery 1.12.4, WordPress 4.7 generator	4	Detected
P–20	/error, /legacy.php, /product?id='	2 of 3 (/product?id=' is reported as SQL injection by A-02)	Detected
P–21	/.git/HEAD, /.git/config, /.svn/wc.db, /.hg/requires	4 of 4	Detected
P–22	/.env, /web.config, /wp-config.php, /application.yml, /appsettings.json, /docker-compose.yml, /.npmrc	7 of 7 (plus /config.php.bak)	Detected
P–23	/backup/	1	Detected
P–24	/config.php.bak, /backup/db.sql.old, /index.php~	2 of 3 (/config.php.bak is reported by P-22)	Detected
P–26	code.jquery.com script without integrity	1	Detected
P–27	AWS key and api_key on /, /keys/deploy_key	3	Detected
P–28	Contact address on /	1	Detected
P–29	/login, /account with no Cache-Control	3	Detected
P–30	No /.well-known/security.txt	1	Detected
P–31	/login password field without autocomplete	1	Detected
A–01	/search?q= echoed raw	1	Detected
A–02	/product?id= (error-based SQL injection)	1	Detected
A–03	/product?id= (boolean-based SQL injection)	1	Detected

A-04	/go?url= open redirect	1	Detected
A-05	Any Origin reflected with credentials	1	Detected
A-07	OPTIONS advertises PUT, DELETE, TRACE	1	Detected
A-09, A-13	/admin, /administrator, /.git/config, /.env, /backup, /backup.zip, /config.php.bak, /phpinfo.php, /server-status	A-09: 9 of 9; A-13: 1	Detected
A-10	/login POST form without a CSRF token	1	Detected
A-11	/download?file= path traversal	0	Missed
A-12	/greet?name= template injection	1	Detected

Missed: A-11 (path traversal) did not report `/download?file=`. This is the one planted weakness the scan did not find, and it is the main item for future work.

Not testable on this lab: P-02, P-11 to P-16, P-25 and A-14 need an HTTPS origin, and A-08 (host header injection) never reaches the lab because the web server sends unknown hosts to its default site.

5. Automated tests

Each package's suite was run with `bun run test` on October 12, 2026.

Package	Passed	Failed	Files	Time
apps/api	342	0	21	56.9 s
apps/web	304	0	18	12.6 s
apps/worker	119	0	13	5.3 s
packages/detectors	185	0	7	0.3 s
packages/scope-guard	52	0	4	<0.1 s
packages/scope-rules	92	0	4	<0.1 s
packages/shared	139	0	6	<0.1 s
Total	**1,233**	**0**	**73**	

6. Screenshots

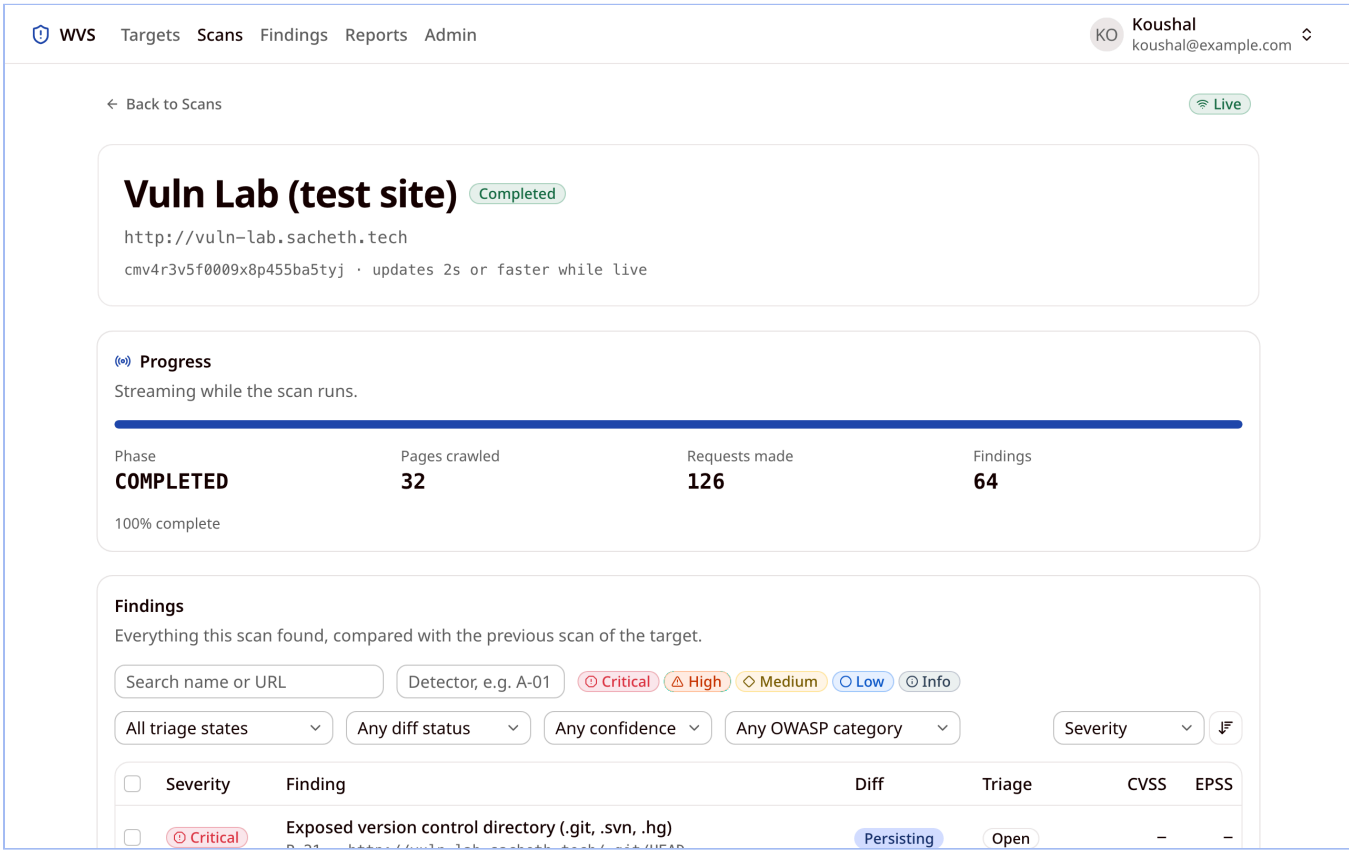


Figure 1: The completed scan: 32 pages crawled, 126 requests, 64 findings.

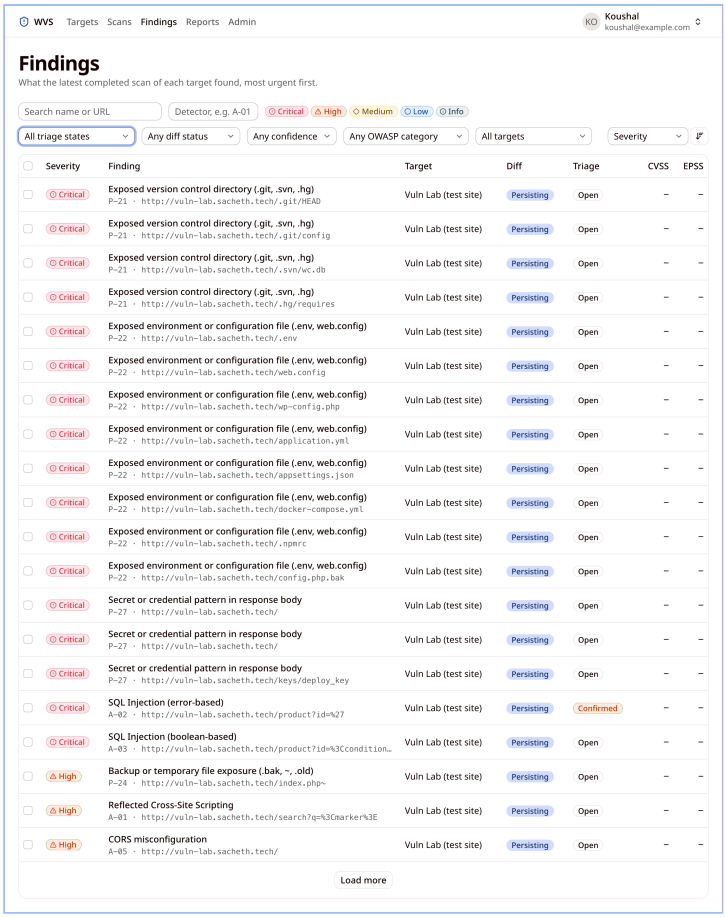


Figure 2: Every finding from the scan, most severe first.

```
$ cd apps/api && bun run test
  342 pass
  0 fail
  Ran 342 tests across 21 files. [56.88s]

$ cd apps/web && bun run test
  304 pass
  0 fail
  Ran 304 tests across 18 files. [12.59s]

$ cd apps/worker && bun run test
  119 pass
  0 fail
  Ran 119 tests across 13 files. [5.29s]

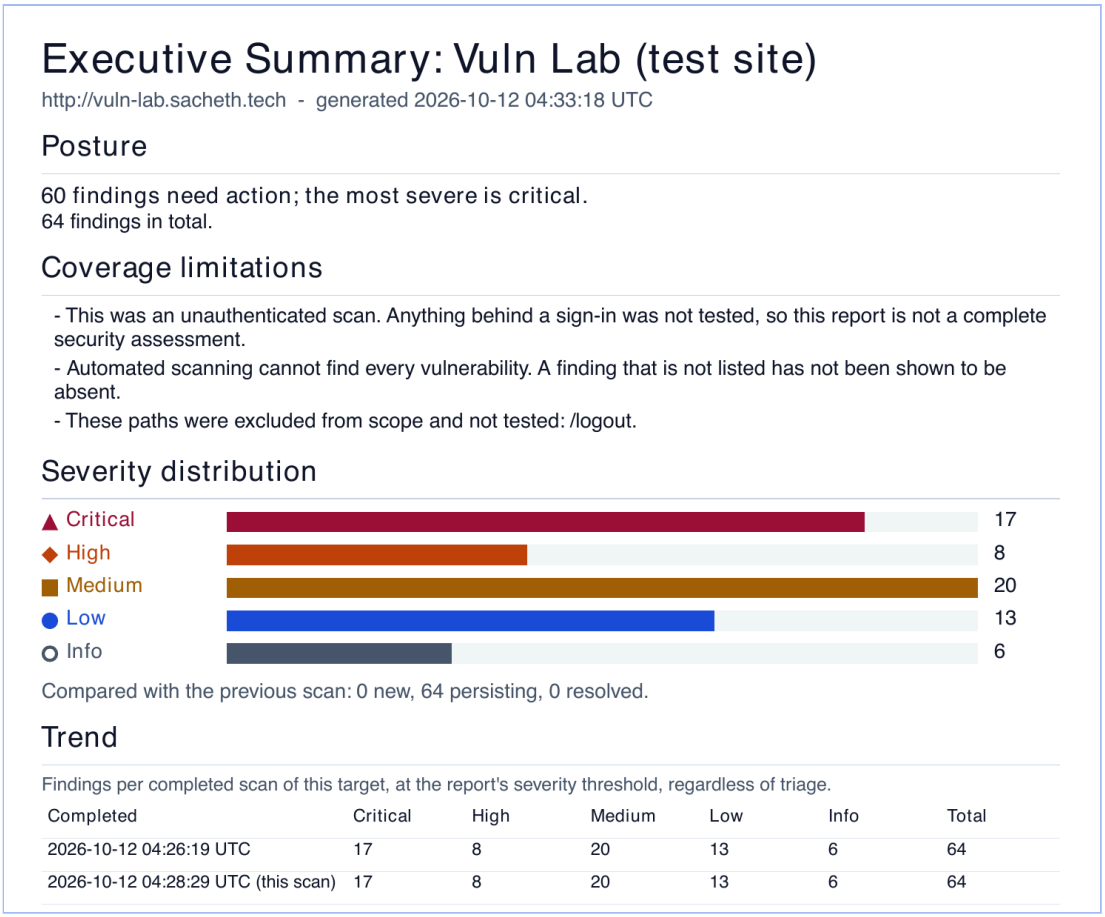
$ cd packages/detectors && bun run test
  185 pass
  0 fail
  Ran 185 tests across 7 files. [347.00ms]

$ cd packages/scope-guard && bun run test
  52 pass
  0 fail
  Ran 52 tests across 4 files. [26.00ms]

$ cd packages/scope-rules && bun run test
  92 pass
  0 fail
  Ran 92 tests across 4 files. [12.00ms]

$ cd packages/shared && bun run test
  139 pass
  0 fail
  Ran 139 tests across 6 files. [12.00ms]
Total: 1233 pass, 0 fail across 7 packages
```

Figure 3: The automated test suite: 1,233 tests, none failing.



Executive Summary: Vuln Lab (test site)

http://vuln-lab.sacheth.tech - generated 2026-10-12 04:33:18 UTC

Posture

60 findings need action; the most severe is critical.
64 findings in total.

Coverage limitations

- This was an unauthenticated scan. Anything behind a sign-in was not tested, so this report is not a complete security assessment.
- Automated scanning cannot find every vulnerability. A finding that is not listed has not been shown to be absent.
- These paths were excluded from scope and not tested: /logout.

Severity distribution

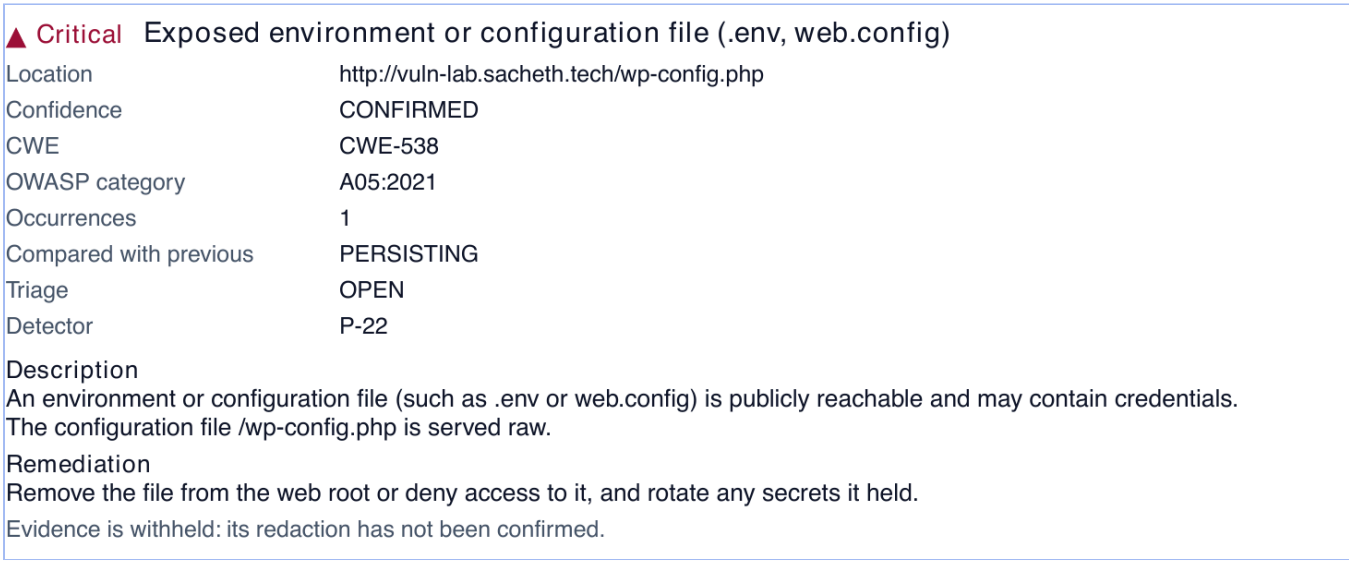
Compared with the previous scan: 0 new, 64 persisting, 0 resolved.

Trend

Findings per completed scan of this target, at the report's severity threshold, regardless of triage.

Completed	Critical	High	Medium	Low	Info	Total
2026-10-12 04:26:19 UTC	17	8	20	13	6	64
2026-10-12 04:28:29 UTC (this scan)	17	8	20	13	6	64

Figure 4: First page of the Executive Summary report generated from the scan.



▲ Critical **Exposed environment or configuration file (.env, web.config)**

Location	http://vuln-lab.sacheth.tech/wp-config.php
Confidence	CONFIRMED
CWE	CWE-538
OWASP category	A05:2021
Occurrences	1
Compared with previous	PERSISTING
Triage	OPEN
Detector	P-22

Description
An environment or configuration file (such as .env or web.config) is publicly reachable and may contain credentials. The configuration file /wp-config.php is served raw.

Remediation
Remove the file from the web root or deny access to it, and rotate any secrets it held.

Evidence is withheld: its redaction has not been confirmed.

Figure 5: A finding as it appears in the Technical Report.

7. Conclusion

WVS found 33 of the 34 detector checks planted in the test website, a 97% detection rate, in under a minute and within its request-rate limit. Its output is triaged in the app and exported as executive and technical reports. All 1,233 automated tests pass. The missed path traversal case (A-11) is the main item for future work.